Threat Analysis Report

รายงานวิเคราะห์ช่องโหว่ระดับ Critical ใหม่บน Redis

08/10/2025

TLP:CLEAR

สำนักงานคณะกรรมการการรักษาความมั่นคงปลอดภัยไซเบอร์แห่งชาติ
๑๒๐ ชั้น ๗ อาคารซี ศูนย์ราชการเฉลิมพระเกียรติ ๘๐ พรรษา ๕ ธันวาคม ๒๕๕๐
ถนนแจ้งวัฒนะ แขวงทุ่งสองห้อง เขตหลักสี่ กรุงเทพมหานคร ๑๐๒๑๐ อีเมล saraban@ncsa.or.th

สารบัญ

สารบัญ 2
บทสรุปสำหรับผู้บริหาร 3
การวิเคราะห์เชิงเทคนิค 4
Technique Tactics and Procedures (MITRE ATT&CK) 6
Indicator of Compromise (IOCs) 7
แนวทางการเฝ้าระวัง ป้องกัน และรับมือ 8
อ้างอิง (References) 9

บทสรุปสำหรับผู้บริหาร

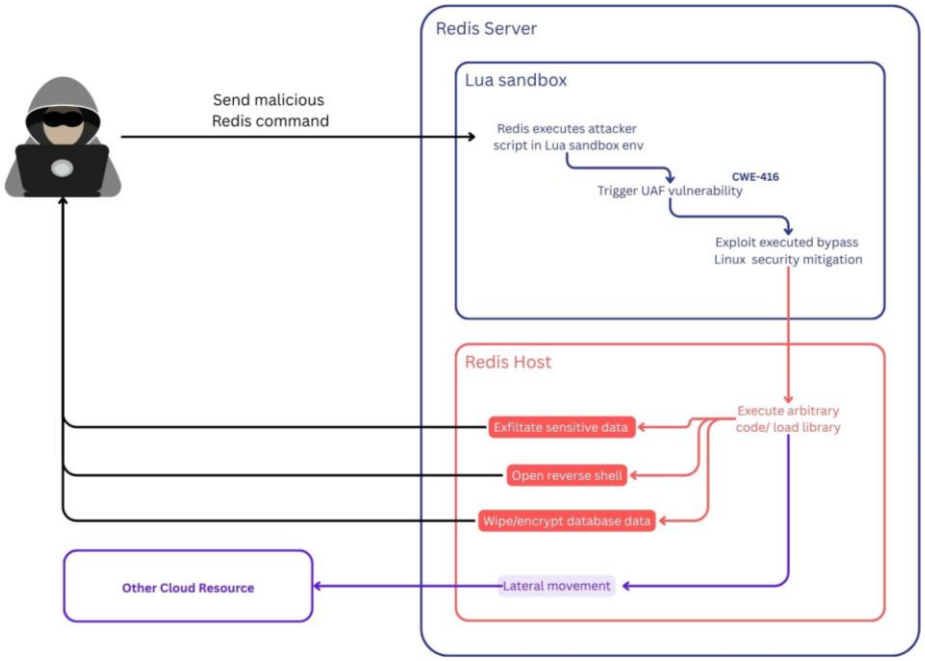
รายงานฉบับนี้วิเคราะห์ช่องโหว่ความปลอดภัยใหม่แบบ Remote Code Execution ที่มีรหัส **CVE-2025-49844** (CVSS 10.0) บนซอฟต์แวร์ Open-Source **Redis** โดยเป็นฐานข้อมูลประเภท In-memory ซึ่งถูกค้นพบโดย Wiz Resarch และได้ให้ชื่อเล่นของช่องโหว่นี้ว่า **#RediShell**

ช่องโหว่นี้อาศัยประโยชน์จากข้อบกพร่องการคอร์รัปต์หน่วยความจำแบบ Use-After-Free (Use-After-Free memory corruption bug) ที่มีอยู่ในซอร์สโค้ดของ Redis มานานกว่า 13 ปี ข้อบกพร่องนี้อนุญาตให้ผู้โจมตีที่ผ่านการพิสูจน์ตัวตนแล้ว (post-auth attacker) สามารถส่งสคริปต์ Lua ที่เป็นอันตรายซึ่งถูกสร้างขึ้นเป็นพิเศษสำหรับการหลบหนีจากแซนด์บ็อกซ์ของ Lua และสามารถที่จะนำไปสู่การรันโค้ดได้โดยตรงบนโฮสต์ของ Redis สิ่งนี้ทำให้ผู้โจมตีสามารถเข้าถึงระบบโฮสต์ได้อย่างสมบูรณ์ ปัจจุบัน Redis ได้ออกแพตช์เพื่อแก้ไขช่องโหว่ดังกล่าวแล้ว องค์กรจึงควรดำเนินการอัปเดตโดยเร่งด่วน

การวิเคราะห์เชิงเทคนิค

Attack Flow

1. **Initial Access:** ผู้โจมตีจะส่งสคริปต์ Lua ที่เป็นอันตรายเพื่อใช้ประโยชน์จากช่องโหว่ Use-After-Free
2. **Sandbox Escape and Code Execution:** เมื่อ Redis รันสคริปต์ Lua ที่สร้างขึ้นมาเป็นพิเศษนี้ สคริปต์ดังกล่าวจะไปกระตุ้นช่องโหว่ UAF ซึ่งส่งผลให้สามารถ Bypass ระบบความปลอดภัยของ Linux ได้และสามารถที่จะรันโค้ดบนโฮสต์ของ Redis ได้โดยตรง
3. **System Compromise:** ผู้โจมตีสามารถที่จะกระทำการอื่น ๆ บนเครื่องเหยื่อเพิ่มเติมได้อาทิ เช่น การขโมยข้อมูล Credential, ติดตั้งมัลแวร์เพิ่มเติม และการขโมยข้อมูลต่าง ๆ จาก Redis และเครื่องโฮสต์
4. **Lateral Movement:** ผู้โจมตีสามารถที่จะใช้งาน IAM Token หรือข้อมูล Credential ที่ขโมยมาได้ในการเข้าถึงบริการคลาวด์อื่น ๆ ของเหยื่อเพิ่มเติม



[แผนภาพการโจมตีช่องโหว่ CVE-2025-49844]

รายละเอียดช่องโหว่ (CVE-2025-49844):

ช่องโหว่เกิดจากข้อบกพร่องของการคอร์รัปต์หน่วยความจำแบบ Use-After-Free (Use-After-Free memory corruption bug) ซึ่งทำให้ผู้โจมตีสามารถที่จะรันโค้ดที่เป็นอันตรายบนโฮสต์ของ Redis ได้โดยตรง ส่งผลให้ผู้โจมตีสามารถที่จะกระทำการอื่น ๆ เพิ่มเติมได้อาทิ เช่น การสร้าง Reverse Shell, ขโมยข้อมูล Credential, ข้อมูลจาก Redis

ผลิตภัณฑ์ที่ได้รับผลกระทบ:

- Redis OSS/CE ทุกเวอร์ชันก่อนเวอร์ชันดังนี้
    - 8.2.2, 8.0.4, 7.4.6, 7.2.11 ขึ้นไป
- Redis Software ทุกเวอร์ชันก่อนเวอร์ชันดังนี้
    - 7.22.2-12, 7.8.6-207, 7.4.6-272, 7.2.4-138, 6.4.2-131 ขึ้นไป

Technique Tactics and Procedures

(MITRE ATT&CK)

MITRE ATT&CK คือฐานความรู้ที่รวบรวมและจัดหมวดหมู่กลยุทธ์และเทคนิคต่างๆ ที่ผู้ไม่หวังดีใช้ในการโจมตีทางไซเบอร์ โดยอ้างอิงจากเหตุการณ์ที่เกิดขึ้นจริง เพื่อให้ฝ่ายป้องกันสามารถเข้าใจและรับมือกับภัยคุกคามได้ดียิ่งขึ้น

Tactic	Technique ID	Technique Name
Lateral Movement	T1210	Exploitation of Remote Services
Execution	T1059	Command and Scripting Interpreter
Defense Evasion	T1497	Virtualization/Sandbox Evasion

Indicator of Compromise (IOCs)

Indicators of Compromise (IOCs) คือ ร่องรอยหรือหลักฐานทางดิจิทัลที่บ่งชี้ว่าระบบหรือเครือข่ายอาจถูกบุกรุกโดยผู้ไม่หวังดี ซึ่งทาง สกมช. ได้มีการแบ่งปันข้อมูล IOCs เหล่านี้ผ่านทางแพลตฟอร์ม MISP (Malware Information Sharing Platform) เพื่อเสริมสร้างความมั่นคงปลอดภัยไซเบอร์เรียบร้อยแล้ว โดยมีร่องรอยที่สามารถตรวจสอบได้ดังนี้

ร่องรอยที่สามารถตรวจสอบได้:

Filename:

exploit_poc.py

SHA 256:

886aaa27ff90ee5a3bedbd8ae6c8a9c90e45172baf79e3c35cd0f6087b9dbf42

แนวทางการเฝ้าระวัง ป้องกัน และรับมือ

การเฝ้าระวัง (Monitoring)

- ตรวจสอบเวอร์ชันของ Redis: หากเวอร์ชันของ Redis ที่กำลังใช้งานนั้นไม่ได้รับการอัปเดตเป็นแพตช์ปัจจุบันที่ได้รับการแก้ไขช่องโหว่นี้ ให้ทำการอัปเดตให้เป็นปัจจุบัน
- เปิดใช้งานระบบ Logging และ Monitoring: เปิดใช้งาน Redis logging and Monitoring เพื่อบันทึกกิจกรรมที่อาจจะไม่ปกติภายในระบบ

การป้องกัน (Prevention)

- ตั้งค่าการยืนยันตัวตนของ Redis: ใช้งานฟังก์ชัน **requirepass directive** สำหรับการตั้งค่ารหัสผ่านเพื่อยืนยันตัวตนเมื่อทำการเชื่อมต่อกับ Redis server
- ปิดใช้งานคำสั่งที่ไม่จำเป็น: หากไม่ได้ใช้งานฟังก์ชันของ Lua script สามารถที่จะตั้งค่าไม่ให้ผู้ใช้ใช้งานสคริปต์ได้
- ใช้งานด้วยสิทธิ์เท่าที่จำเป็น: ใช้งาน Redis ด้วยบัญชีที่ไม่ใช่สิทธิ์ root
- จำกัดการเข้าถึง Redis: กำหนดให้เข้าถึงด้วยเครือข่ายที่ได้รับอนุญาตเท่านั้น
- ใช้งาน Access Control บน Network-Layer: ใช้งานอุปกรณ์อย่างเช่น Firewalls และ Virtual Private Clouds (VPCs)

การรับมือ (Response)

- แยกอุปกรณ์ที่ติดเชื้อ: หากตรวจพบการบุกรุก ให้รีบตัดการเชื่อมต่อโฮสต์นั้นออกจากเครือข่ายเพื่อป้องกันการติดต่อกับผู้โจมตี
- เก็บหลักฐานทางดิจิทัล: รักษาสภาพของเครื่องที่ติดเชื้อไว้เพื่อการวิเคราะห์หาสาเหตุและสืบสวน (Digital Forensics)
- เปลี่ยน/เพิกถอน Credential สำคัญ: เปลี่ยน หรือ เพิกถอน IAM tokens, service account keys, SSH keys ที่อาจถูกขโมยไปจากโฮสต์
- รายงานเหตุการณ์: แจ้งเหตุการณ์ไปยังหน่วยงานที่เกี่ยวข้องภายในองค์กรและหน่วยงานด้านความมั่นคงปลอดภัยไซเบอร์

อ้างอิง (References)

1. National Vulnerability Database
   nvd.nist.gov/vuln/detail/CVE-2025-49844
2. Wiz article "RediShell: Critical Remote Code Execution Vulnerability (CVE-2025-49844) in Redis, 10 CVSS score"
   https://www.wiz.io/blog/wiz-research-redis-rce-cve-2025-49844?fbclid=IwY2xjawNRwy9leHRuA2FlbQIxMQABHmJxlybgYIuj1wGABb4iLL5K1R-cGnHDeEWEBmt3EW6glep2pbpIUd3uwP2A_aem_kJWpc5mMZNgyRWKuUg86aw

แบบประเมินรายงานข่าวกรองไซเบอร์

https://dg.th/nsexlfob51

จัดทำโดย

ฤทธิ์นภา ประเสริฐศรี

ฝ่ายบริหารจัดการข้อมูลภัยคุกคามทางไซเบอร์ สำนักประสานงาน
ศูนย์ประสานการรักษาความมั่นคงปลอดภัยระบบคอมพิวเตอร์แห่งชาติ
โทร: 02 114 3531 อีเมล: cti_misp@ncsa.or.th